

CALARO release readiness report

Validation, session security, Selenium end-to-end tests and dependency scans before going live on **calaro.online**.
Tested on 8 October 2026.

Verdict: ready to deploy, with four setup steps on the server (section 7). Every automated check passes. Testing found 6 issues and all were fixed before this report. Two things could not be tested from the build machine and should be checked once the site is live: live voice through Bhashini, and the full Docker monitoring stack.

1. Results at a glance

Check	What it covers	Result
Backend automated tests	API, food matching in 8 languages, onboarding plan maths, admin roles, monitoring sign-in, security rules	Pass: 53 of 53
Selenium end-to-end tests	21 real-browser journeys: sign-up, onboarding, logging meals, history, profile, admin, sessions, lockout, password reset, phone layout	Pass: 21 of 21 (two runs in a row)
Accessibility (axe-core, WCAG 2 A/AA)	Sign-in, plan, Today and Admin screens	0 problems (22 fixed)
Python dependency audit (pip-audit)	All 48 backend packages against the PyPI vulnerability database	0 known (3 fixed)
JavaScript dependency audit (npm audit)	All 239 frontend packages	0 known (16 fixed)
Static code scan (Bandit)	Backend Python source	0 medium or high; 4 low, all false alarms
Monitoring dashboards	47 Grafana panels: metric names exist and every query parses	0 errors

2. Issues found and fixed

#	Found by	Issue	Fix	Status
1	Selenium	The dish-search suggestions were invisible: the green panel clipped the dropdown, so people couldn't add a missed dish by name.	Panel no longer clips; the list opens below the search box.	Fixed, re-tested
2	axe-core	Grey helper text and some labels were below the 4.5:1 contrast ratio, which made them hard to read for low-vision users (22 places).	Darkened the grey text and lightened the green panel text. Now 5.1:1 and 5.4:1.	Fixed, re-tested
3	pip-audit	python-jose, the sign-in token library, has a published vulnerability (CVE-2026-85394), as does its ecdsa dependency, and neither has a fix.	Replaced with PyJWT, now recommended by FastAPI's documentation.	Fixed, re-tested
4	npm audit	axios (used to call the API) and several build tools had known high-severity issues.	Updated axios to 1.20 and applied compatible updates.	Fixed, re-tested
5	Your Docker run	Grafana showed its start screen: Caddy removed the admin identity headers after adding them, because of its built-in step order.	Grafana steps wrapped in a route block so they run in the written order.	Fixed: confirm Monitoring shows dashboards
6	Your Docker run	Server-stats container failed on Docker Desktop for Windows (unsupported disk-mount option).	Switched to the standard mounts that work on Windows and Linux.	Fixed

3. Validation and session security now in place

Area	Rule	Tested by
Passwords	8 to 128 characters with at least one letter and one number, no leading or trailing spaces. Rules show live as you type.	Backend + Selenium
Sign-up fields	Valid email; names of 80 characters or fewer with no HTML or control characters; supported language codes only; duplicate emails refused.	Backend + Selenium
Meals and profile	1 to 30 foods per meal, sensible quantity and nutrient ranges, text up to 1,000 characters; age 13 to 100, height 100 to 250 cm, weight 25 to 300 kg.	Backend + Selenium
Wrong passwords	5 wrong passwords for one account pauses sign-in for 15 minutes; 30 failures from one network pauses that network. Stored in the database, so it survives restarts.	Backend + Selenium
Rate limits	10 sign-ups per hour per network, 5 reset codes per 15 minutes per email, 30 meal requests per minute per person.	Backend
Sign-in lifetime	Sessions last 12 hours at most (previously 7 days).	Backend
Inactivity	Members are signed out after 30 minutes without activity and admins after 15, across all open tabs, with a clear message.	Selenium
Revoking sessions	Changing a password, deactivating an account or changing a role ends every existing session immediately. Tampered tokens are rejected.	Backend + Selenium
Admin areas	Members get 403 from every admin API. Admins can't manage admins. Only calaro@admin.calaro.com can open Admin team.	Backend + Selenium
Monitoring (Grafana)	HttpOnly, SameSite=Strict cookie lasting 2 hours, re-checked against the database on every request. Forged identity headers are stripped. Signing out ends it.	Backend + browser
Password reset	6-digit code stored hashed, expires in 15 minutes, 5 tries. It never reveals whether an email has an account.	Backend + Selenium
Script injection	Text such as typed as a meal is shown as plain text and never runs.	Selenium
Web server	HTTPS with HSTS; clickjacking protection (frame-ancestors 'self'); nosniff; microphone allowed on CALARO only; 10 MB request cap; the database and /metrics are never exposed to the internet.	Config review

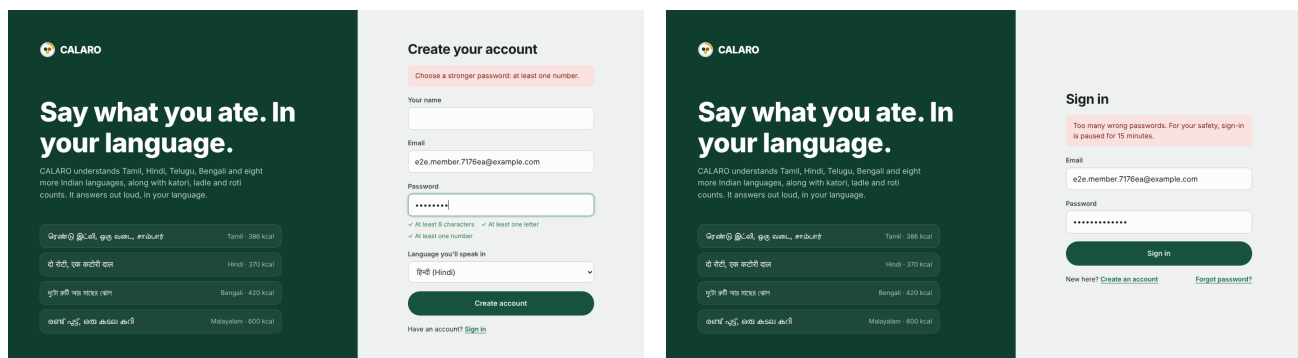
4. Selenium end-to-end tests

Chrome (headless) driven by Selenium 4.50 against the production build of the app, the real FastAPI backend and an in-memory MongoDB. The suite is in e2e/, so you can rerun it against the Docker stack or the live site (section 6).

#	Journey	Time	Result
1	Sign-in page loads, accessible	1.6 s	Pass
2	Sign-up rejects a bad email and a weak password; live password rules	2.1 s	Pass
3	New member lands on the setup questions; empty step is blocked	2.2 s	Pass
4	Duplicate email can't sign up	1.8 s	Pass
5	All 5 setup steps, a bad target weight is refused, the plan is generated	5.0 s	Pass
6	Tamil sentence matches 3 dishes, quantity change recalculates, meal saved	4.3 s	Pass
7	Add a dish by name from search	2.9 s	Pass
8	Script typed as a meal is not executed	3.2 s	Pass
9	History shows the day's meals	2.7 s	Pass
10	Delete a meal	3.7 s	Pass
11	Weight change recalculates the daily goal	3.6 s	Pass
12	Member sees no admin menu; admin APIs return 403	2.1 s	Pass
13	Sign out clears the session; reload stays signed out	2.9 s	Pass
14	Invalid or expired token returns to sign-in with a message	2.6 s	Pass
15	Inactivity sign-out with a message	11.4 s	Pass
16	5 wrong passwords pause sign-in, even with the right password	4.2 s	Pass
17	Super-admin: console, people list, adds an admin, change log	4.0 s	Pass
18	Admin sees the console and Monitoring, but not Admin team	2.9 s	Pass
19	Deactivated member can't sign in	6.2 s	Pass
20	Password reset with an emailed code	3.1 s	Pass
21	Phone size: no sideways scrolling; bottom tab bar	2.1 s	Pass

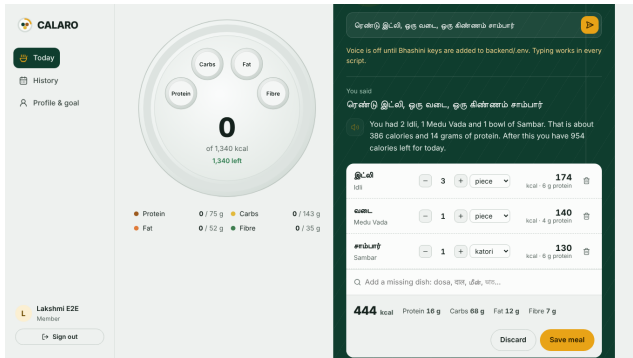
Total 74 seconds. Ran twice in a row with identical results. In test builds only, the idle timer is shortened to 6 seconds so the inactivity sign-out can be checked quickly. Production builds ignore this setting.

5. Screens captured during the run

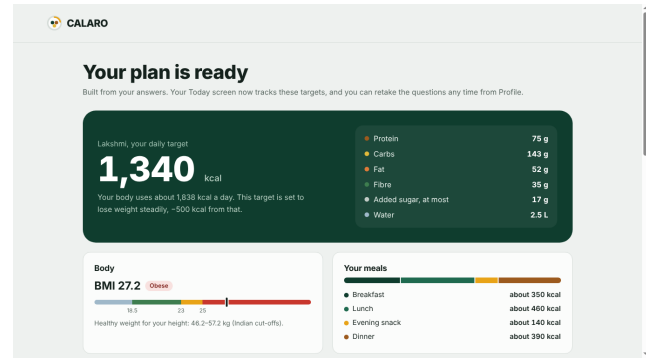


Password rules update live as you type

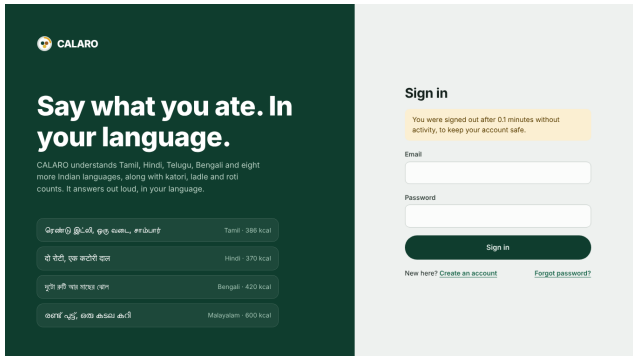
Sign-in paused after 5 wrong passwords



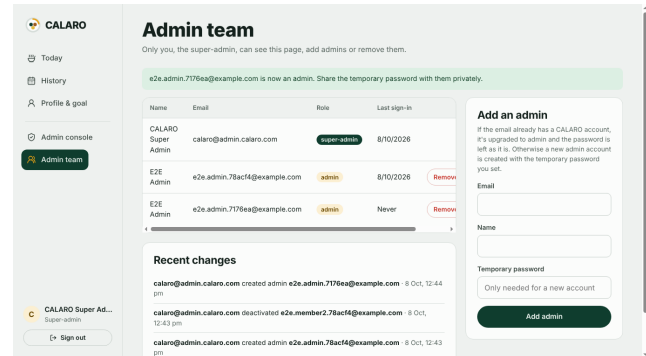
Tamil sentence matched to dishes with portions



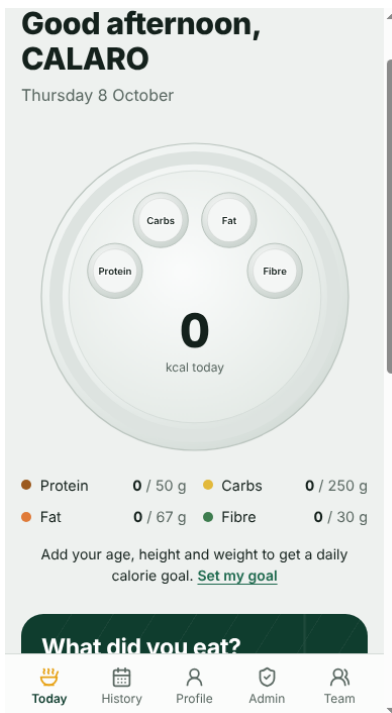
Personal plan after the setup questions



Signed out after inactivity, with the reason



Super-admin adds an admin; change log



Phone layout (390 px wide)

The phone check confirms there's no sideways scrolling, the bottom tab bar shows and the side menu is hidden. Screenshots were taken in the test machine's headless Chrome, which can't load Google Fonts, so they use fallback fonts. The live site uses Bricolage Grotesque, Hind and Noto.

6. Not covered from the build machine

Area	Why	How to check
Live voice (Bhashini)	No Bhashini key on the build machine. Voice is tested with recorded Bhashini responses, typed meals were tested for real.	On the live site, speak a meal in Tamil or Hindi. Or run <code>python scripts/check_bhashini.py</code> on the server.
Full Docker stack with real Grafana, Prometheus, Loki and Caddy	These couldn't be downloaded on the build machine. You ran the stack locally; two issues found there are fixed (section 2, items 5 and 6).	Admin console, then Monitoring: all three views should show data.
Real email sending	No SMTP server configured. Reset codes were read from the backend log in the test.	Set <code>SMTP_*</code> in <code>backend/.env</code> , then try Forgot password.
Load and performance	Not part of this round.	Watch API speed (p95) and errors on the Monitoring dashboard after launch.
Real MongoDB	The automated tests used an in-memory MongoDB that behaves the same way. The Docker stack uses MongoDB 7.	Run the Selenium suite against your Docker stack or the live site (command below).

Rerun the Selenium suite yourself (Chrome must be installed; Selenium downloads its driver automatically):

```
pip install -r e2e/requirements.txt
$env:E2E_BASE_URL="http://localhost" # or https://calaro.online
$env:E2E_SUPER_PASS="<super-admin password>"
python -m pytest e2e -v
```

The suite creates test accounts with unique emails. Against the live site, delete them afterwards from Admin console, then People. The idle-timeout test needs a test build, so it's skipped on production builds.

7. Go-live checklist for calaro.online

Step	Detail	Status
1. Secrets in <code>backend/.env</code>	Set <code>SECRET_KEY</code> (<code>openssl rand -hex 32</code>), <code>SUPERADMIN_PASSWORD</code> and your Bhashini keys. Change <code>ACCESS_TOKEN_EXPIRE_MINUTES</code> from 10080 to 720: your existing <code>.env</code> was copied from the old template and would otherwise keep 7-day sessions.	To do
2. Free server	Oracle Cloud Always Free, Ampere A1, 2 OCPU and 12 GB, Ubuntu 24.04, Mumbai or Hyderabad region. Open TCP 80 and 443 and UDP 443. Then run <code>deploy/server-setup.sh</code> .	To do
3. Hostinger DNS	hPanel, then Domains, <code>calaro.online</code> , DNS. Point the A record @ at the server IP, keep CNAME <code>www</code> pointing at <code>calaro.online</code> , and delete any AAAA records. If CAA records exist, one must allow <code>letsencrypt.org</code> .	To do
4. Start and verify	Set <code>SITE_ADDRESS=calaro.online</code> and <code>PUBLIC_URL=https://calaro.online</code> in <code>.env</code> , run <code>docker compose up --build -d</code> , then run the Selenium suite against <code>https://calaro.online</code> and add the nightly backup cron.	To do

Full step-by-step instructions are in **DEPLOY.md** in the project folder. Test environment: Ubuntu 24.04, Python 3.13, Node 22, Chromium 141 with ChromeDriver 147 (version check disabled), Selenium 4.50, pytest 9, axe-core 4, Bandit, pip-audit, npm audit.